

PatchIQ-iA Security Analysis

Sample 04 — Insecure Deserialization Detection

1. Objective

The objective of this test is to evaluate whether PatchIQ-iA can detect insecure deserialization when user-controlled data is passed directly to `pickle.loads()`. The test uses a small user-data loading utility containing an intentionally vulnerable deserialization operation.

2. Input Code

The following Python code was submitted as part of the Pull Request. The code directly deserializes user-controlled input using `pickle.loads()`.

```
import pickle

def load_user_data():
    print("User Data Loader")
    print("-----")

    data = input("Enter serialized user data: ")

    if not data:
        print("No data provided.")
        return

    try:
        # Vulnerable: user-controlled data is directly deserialized
        user_data = pickle.loads(data)

        print("User data loaded successfully:")
        print(user_data)

    except Exception as error:
        print("Failed to load user data:", error)

def main():
    print("PatchIQ-iA User Data Manager")
    print("-----")

    load_user_data()

if __name__ == "__main__":
    main()
```

3. PatchIQ-iA Output

The following screenshot shows the actual security review generated by PatchIQ-iA for this Pull Request.

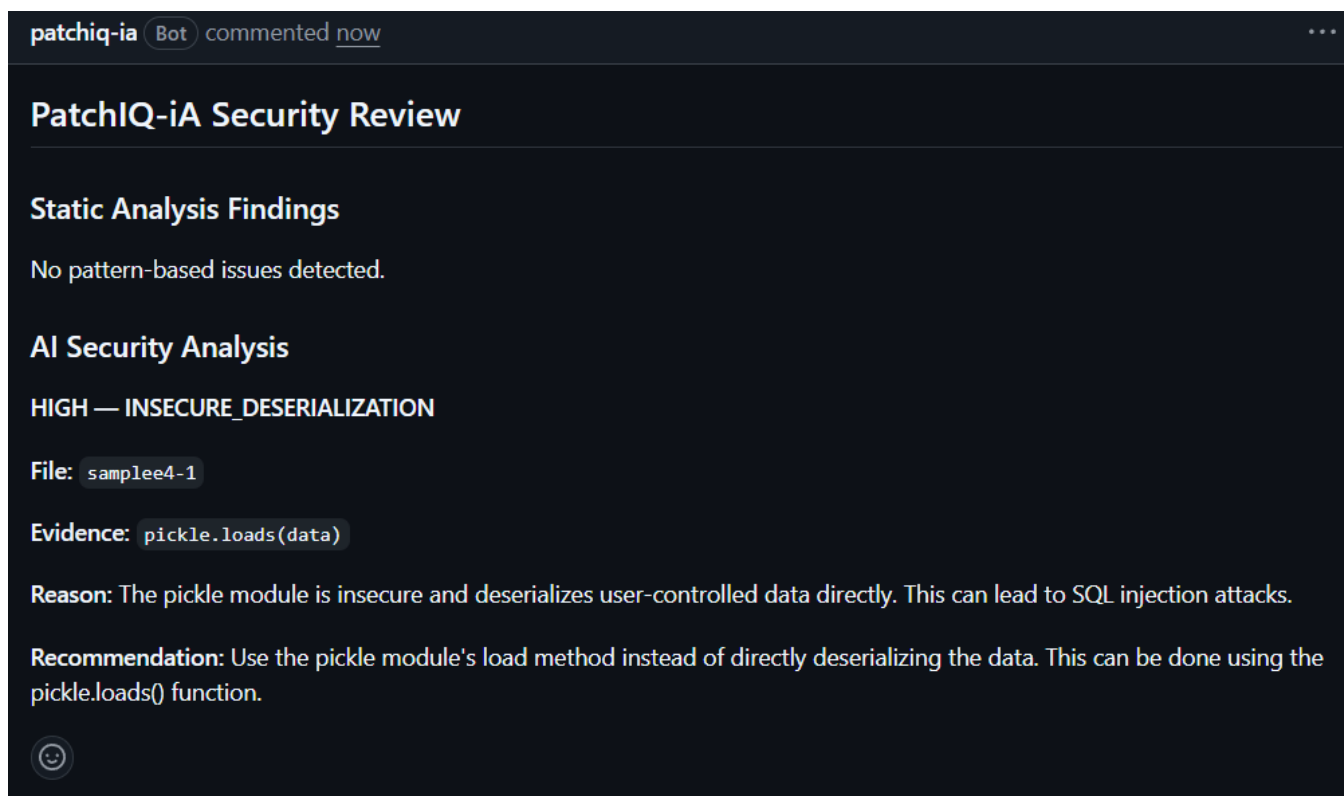


Figure 1. Actual PatchIQ-ia Security Review generated during the test.

4. Conclusion

PatchIQ-ia successfully detected the insecure deserialization vulnerability through AI security analysis. The finding was classified as HIGH severity, with evidence identifying the `pickle.loads(data)` operation. The analysis recognized that user-controlled data is being deserialized directly and generated a corresponding security recommendation.